

Krakencreds

A new way to potentially end most credential phishing

Krakencreds are a new cybersecurity framework that aims to make the phishing of credentials implausible for most attackers. It was invented in view of how widespread the following type of attack was:

1. The attacker creates a fake site or account to impersonate a real site, trusted individual or organization.
2. Through social engineering, link spoofing or other methods, they direct users to the fake site or account.
3. The user is asked to enter their credentials (for an alleged verification, for emergency protection or simply for logging in after supposedly having been logged out), and as the page looks legitimate, they duly provide them.
4. The attacker can now enter the credentials to log into the user's account, and will often immediately change the password to permanently lock them out. If it was a site, then the credentials will either be stored for use or tested on the real site by a bot to ensure they are not incorrect. And even if the site uses 2-factor authentication (2FA), where a verification code which must be entered to log in is sent only to the user's email (and this is still the most robust method of authentication in many sites and applications at the moment), this can also be easily bypassed by mimicking the page for entering the code as well, as, if the credentials entered were indeed correct, the aforementioned bot will have triggered the code to be sent, raising no further suspicion that the login is fake. And once the user enters the code in the fake site as well, it is game over.

The procedure

1. A new API is added to the authentication system which generates a set of Krakencreds on request (for example, a username and password). The process should be made as seamless as possible to avoid friction. These credentials will be completely dynamic and private to the user (if they were published on a public "[some site] Krakencreds" page, the attacker could easily handle them in the bot's code to avoid entering them). They can also be random, which is easier to implement and will trick any bot, or purposefully human-like (taken from a database of common credentials or generated from existing words, for example), which will also raise no suspicion to humans if executed correctly.

2. A user who has noticed they are being the victim of a phishing attempt generates a set of Krakencreds and gives them to the attacker or enters them on the fake site instead of the real ones.
3. The attacker or bot enters the Krakencreds on the official site with the intent of taking control of the user's account or generating the 2FA code.
4. Upon detecting that a set of Krakencreds has been entered, the authentication system immediately triggers a system-level ban which blocks all login attempts from the attacker's current device. This can be done through Hardware IDs (most suitable for device apps), browser fingerprinting, evercookies or other methods depending on the setup. And given that the attacker most certainly does not have an infinite supply of devices, this ban becomes completely prohibitive.

This provides a highly effective way to prevent many kinds of phishing attacks while entailing basically no monetary cost and relatively little additional software.

Some points addressed

Going into the official page, potentially logging in and generating the krakencreds is still too much friction for most users to actually do this. Even though the cumulative probability would still be prohibitive in that case, the friction could be greatly reduced if browsers and password managers added a native "I'm being phished" button that interfaced with the Krakencreds APIs to automatically fill in the login boxes with Krakencreds on the click of a button by just selecting which site is being spoofed, or even autonomously upon detection of a known-spoofed site.

But this only works if the user realizes they're being a victim of a phishing scam, which is precisely what these scams are meant to avoid. Yes, but it only takes a single experienced or simply attentive person entering the Krakencreds to completely take down the attacker, and many times, this is not actually too hard; unless one is clicking links absent-mindedly, a spoofed link like [github.com.ge](#) is not hard to spot (this is for example's sake, of course there are more subtle ones, but in any case they can always be noticed). From the perspective of the attacker, if they have a bot sending the phishing scam to hundreds or thousands of users, the cumulative probability that one of them will see through it (which, [according to CISA](#), could be a relatively high 13% per victim) results in a risk which simply cannot be plausibly taken.

But what if the attacker is running their bot on an unsuspecting individual's infected device? That individual will get unfairly banned from the platform. This is the exception where the phisher has control over something like a residential proxy network. While most of the devices in such a network are things like smart TVs which, for most platforms, can be safely banned with no further consequence for the innocent owner, an automated ban appeals system could also be set up,

requiring stricter methods of verification like an ID, a passport, an authenticator app or a passkey, among others. Additionally, if applicable, a notification should be displayed that the device is infected, allowing for the vulnerability or malware to be discovered and sent to public databases for antiviruses to eliminate in other infected devices, potentially ending the entire network. Friction could be removed from this process by having antivirus software interface with the Krakencreds API.